

A Decentralised Public Key Infrastructure for X-Road

Mariia Bakhtina, Kin Long Leung, Raimundas
Matulevičius, Ahmed Awad
University of Tartu
Tartu, Estonia
{bakhtina,kin.long.leung,rma,ahmed.awad}@ut.ee

Petr Švenda
Masaryk University
Brno, Czech Republic
svenda@fi.muni.cz

ABSTRACT

X-Road is an open-source solution that acts as a data exchange layer and enables secure data exchange between organisations. X-Road serves as the backbone of digital infrastructure in the public sector (e.g., enabling Estonia’s digital public services) and private sector (e.g., enabling clients’ data exchange in the Japanese energy sector). An approach and architecture were recently proposed for the X-Road data exchange systems to move from public key infrastructure (PKI) with centralised certification authorities to decentralised PKI (DPKI). In this paper, we develop a proof of concept for the designed DPKI-based architecture that leverages distributed ledger-based identifiers and verifiable credentials to establish trust between information systems using Hyperledger Indy and Hyperledger Aries. We evaluate the proof of concept implementation against the design and functional requirements. The results show that the proposed system architecture is technically feasible and satisfies the identified design goals and functional requirements. To the best of our knowledge, this paper presents the first open-access system prototype for an organisation’s identity management following self-sovereign identity principles. The presented proof of concept proves that DPKI helps to address some of the scalability issues of PKI, improve control over identity and mitigate replay attacks and a single point of failure in the X-Road system.

CCS CONCEPTS

• **Software and its engineering** → **Designing software**; • **Computer systems organization** → **Distributed architectures**; • **Information systems** → **Enterprise information systems**.

KEYWORDS

decentralised public key infrastructure, proof of concept, decentralised identifier, verifiable credentials, distributed ledger, X-Road

ACM Reference Format:

Mariia Bakhtina, Kin Long Leung, Raimundas Matulevičius, Ahmed Awad and Petr Švenda. 2023. A Decentralised Public Key Infrastructure for X-Road. In *The 18th International Conference on Availability, Reliability and Security (ARES 2023)*, August 29–September 01, 2023, Benevento, Italy. ACM, New York, NY, USA, 8 pages. <https://doi.org/10.1145/3600160.3605092>



This work is licensed under a Creative Commons Attribution International 4.0 License.

ARES 2023, August 29–September 01, 2023, Benevento, Italy
© 2023 Copyright held by the owner/author(s).
ACM ISBN 979-8-4007-0772-8/23/08.
<https://doi.org/10.1145/3600160.3605092>

1 INTRODUCTION

Communication with external entities is crucial for businesses, as well as for governmental agencies, to provide essential services. To ensure secure communication, organisations must establish trust with their counterparts. Public key authentication enables trust between two entities online, but exchanging public keys in advance is impractical if there are many information systems to communicate with. Public key infrastructure using X.509 (PKIX) [8, 29] solves such scaling problems by introducing transitive trust, which turns trust between two parties into trust to a third party [17]. However, PKIX has limitations, including the varying procedure of credentials issuance and scalability issues, as well as centralised dependency on a third party for the credentials update. The concept of Self-Sovereign Identity (SSI) eliminates the need for a single third party and allows immediate updates on the change of the certificate status. It brings new standards that can facilitate a decentralised public key infrastructure (DPKI) using decentralised identifiers (DIDs) and verifiable credentials (VCs) [1, 23, 27].

Our study explores the effects of SSI concepts in data exchange systems. In the previous work [4], the authors presented an approach for analysing and assessing identity management systems in the context of business operations and information systems. The application of the approach to the business context of X-Road¹ data exchange systems has resulted in the proposed architecture for the DPKI-based X-Road. In this paper, we validate the artefact proposed in [4], namely the architecture. The main research question (RQ) of this paper is as follows: *how to establish trust between information systems using a decentralised public key infrastructure in X-Road?* In this paper, we study X-Road, a centrally managed distributed data exchange layer, and propose the proof-of-concept (PoC), which aims to overcome the limitations of PKIX for authentication and verification. For this purpose, the PoC follows the proposed architecture with DPKI built with Hyperledger Indy [32]. The paper is based on the PoC developed in [21], and it extends the presented there results by explaining how the PoC fits into the design science research on the identity management system transformation. The paper result in a PoC accessible through the GitLab repository with the demonstration scenario. Hence, the X-Road community can benefit from the research results for further research and development on SSI usage in X-Road.

2 BACKGROUND

According to Cameron [7], *digital identity* denotes the information provided by a digital subject regarding either its own identity or that of another digital subject. *Identity management* (IdM) includes the policies and technologies implemented to ensure that resource

¹<https://x-road.global/>

users have authorized access to those resources based on their identity characteristics. IdM operations typically involve the use of credentials for purposes of identification and verification. One of the ways of managing digital identities and PKI credentials is using certificates based on the public key infrastructure (PKI) with X.509 standard (i.e., PKIX) [8, 29] and/or verifiable credentials (VCs). PKIX certificates are generally one-purpose specific – such certificates are issued to confirm that the issuing certification authority (CA) trusts the entity that manages the claimed system component. The PKIX-based system is centralised and, therefore, prone to a (multiple) single point failure when relying on the (multiple) root CAs. Revocation of certificates can be accomplished through the use of a certificate revocation list (CRL) or the Online Certificate Status Protocol (OCSP). CRLs have limitations regarding time granularity and resource consumption. OCSP presents privacy and denial-of-service vulnerabilities. To address these issues, a decentralised public key infrastructure (DPKI) has been proposed [2].

2.1 Decentralised Public Key Infrastructure

In 2015, the Decentralised Public Key Infrastructure (DPKI) was introduced as an alternative approach to PKIX [2]. The goal of DPKI is to enhance security by leveraging distributed ledger technologies (e.g., blockchain or key event receipt infrastructure) to ensure no single third party can compromise the system. In DPKI, an entity creates and registers a globally unique identifier and associated data, such as public keys in a blockchain, with full control and ownership of the identifier. Validators or miners secure blockchain integrity. The DPKI eliminates the man-in-the-middle threat that can occur in PKIX [2], and its globally unique identifier concept has evolved into its own specification, Decentralised Identifier (DID), becoming a fundamental component of the self-sovereign identity model [28].

Decentralised Identifier (DID). A Decentralised Identifier (DID) is a globally unique identifier that does not require a centralised registration authority and is generated and/or registered cryptographically [28]. It is a type of URI scheme that resolves to a DID document containing data which describes the DID subject, including verification methods such as cryptographic public keys. The DID format includes a “did:” prefix, a DID method, and a method-specific identifier. The DID method defines how DIDs and DID documents are created, resolved, updated, and deactivated. Some DID methods use distributed ledger technology (DLT) to record data in cryptographically signed transactions, referred to as DLT-based DIDs in this paper.

In contrast to PKIX certificates, both end-entity certificates and DID documents may include subject attributes. However, the information contained in DID documents is self-asserted, making them akin to self-signed certificates that are not issued by a centralised authority. While a CA can revoke an end-entity certificate, a DID’s decentralised nature prevents it from being revoked. Instead, certain DID methods allow for the removal and modification of verification methods within the DID document. Furthermore, a DID document does not convey third-party claims about the DID subject, as certificates do with claims asserted by the CA. For this reason, Verifiable Credentials are used.

Verifiable Credentials. According to Preukschat et al. [27], a verifiable credential (VC) is a set of information that a trusted authority, known as an issuer, asserts about the subject of the credential in a tamper-resistant manner. Typically, the holder of the VC is the subject. The purpose of VCs is to provide proof of a statement about the VC’s subject to a verifier. When presented with a VC, the verifier must be able to determine who issued the credential, confirm that the VC has not been tampered with since issuance, and ensure that the VC has not expired or been revoked. The Verifiable Credentials Data Model v1.1 [34] is an open standard that provides a format for digital credentials that are secure, privacy-respecting, and machine-verifiable.

Verifiable credentials (VCs) are typically identified by unique identifiers, although the specific documents that serve as VCs may vary. Traditionally, these identifiers have been based on a PKI model, wherein certificates are issued by centralised CAs. However, with the growing adoption of SSI, the elimination of centralised authorities has become increasingly popular. This approach offers several benefits, including the elimination of single points of failure and the potential automation of credential issuance.

PKIX certificates are not the VCs, as the VC has the characteristics of being able to produce a *verifiable presentation* (VP) which is presented to the verifier instead of showing the full original credential. A VP is a tamper-evident presentation encoded in such a way that authorship of the data can be trusted after a process of cryptographic verification. Like there are different DID methods, there are different VC implementations that support different features such as selective disclosure, derived predicate and revocation. While not necessary, some implementations use DIDs for expressing identifiers associated with subjects and issuers. In this paper, a VC implementation that uses DLT-based DIDs is referred to as DLT-based VC. AnonCreds [10] is an example of DLT-based VC that supports selective disclosure, derived predicate, and revocation.

Identity Agent. In the context of verifiable credentials (VCs), *identity wallet* refers to a secure storage system for a holder’s credentials. Meanwhile, an *identity agent* is a software that enables the holder to manage their digital wallet and establish secure connections with other agents for exchanging credentials and DIDs [15]. Thus, to represent the holder’s identity, an agent uses its wallet content to execute cryptographic operations.

2.2 The X-Road System

X-Road is a centrally-managed distributed data exchange layer between information systems that provides a standardised and secure way to produce and consume data services over the web within the trusted network [25]. As the owner of an X-Road ecosystem, the X-Road Governing Authority controls which organisations can join the ecosystem and defines the onboarding process and regulations that the ecosystem must follow. The X-Road Operator operates the central components of the X-Road software, including the Central Server. X-Road Members are organisations that have joined the ecosystem. Every X-Road Member must have access to the technical component that is required for exchanging messages via X-Road, the Security Server. Figure 1 shows the X-Road architecture.

Central Server (CS) manages and distributes the global configuration of the X-Road instance that Security Servers use for mediating

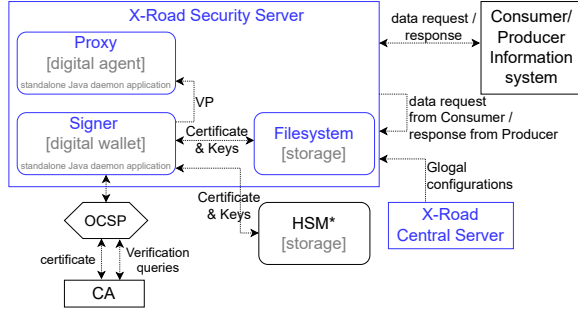


Figure 1: X-Road Architecture (adapted from [3])

the messages sent via X-Road. The global configuration consists of the registry of X-Road members and their Security Servers, and the security policy (incl. a list of trusted certification authorities, a list of trusted time-stamping authorities, and configuration parameters).

Security Server (SS) handles service calls and responses between information systems of X-Road members. It encapsulates the security aspects of the infrastructure including key management, secure message exchanges, non-repudiation message creation, time-stamping, and logging. A single Security Server can host several organisations. The operator of the Security Server is the server owner, while the hosted organisations are the clients. The Security Server manages two types of keys: authentication keys for establishing secure communication channels with other Security Servers and signing keys for clients to sign exchanged messages. During the onboarding process, the identity of each organisation and the Security Server are verified by trusted Certification Authorities, and long-term certificates are issued for the keys.

In X-Road, Security Servers use the OSCP protocol offered by the OSCP responder belonging to a trusted CA to query the certificate validity information. The Security Server does not use the nonce extension in the OSCP request that enables optimisation strategy using the pre-created OSCP responses and cached responses to reduce the load in the OSCP service and increase availability [24]. On the one hand, this makes the X-Road ecosystem vulnerable to replay attacks in which a revoked certificate is accepted for authentication and signing. On the other hand, the fetch interval is set up by the X-Road Operator and is 20 minutes by default, which limits the replay attacks execution time [20]. Still, the usage of DPKI enables the elimination of possible replay attacks thanks to the use of fresh non-revocation proofs, which, however, does not cause the high load on a single OSCP service due to the usage of distributed decentralised nodes for the revocation list storage.

In the recent report by NIIS (an organisation responsible for the open-source X-Road core development) [3], the authors discuss how the shift to the decentralised public key infrastructure can contribute to the X-Road trust model and member management. In the proposed design which was also elaborated in [4], X-Road members manage their DIDs and VCs in their own SSI-compatible digital wallets. DLT-based DIDs and DLT-based VCs are used to replace X.509 certificates for authentication and signing. The use of VC for verification enables privacy-preserving benefits, such as selective disclosure and zero-knowledge proof, which increases the

control over the credentials the identity holder has. In this paper, we validate the proposed design from the report [3] through the proof-of-concept to demonstrate the feasibility of using DIDs and VCs in the X-Road for onboarding and access control.

3 RELATED WORK

Soltani et al. [31] proposed the use of SSI and distributed ledger technology for improving client onboarding and Know Your Customer (KYC) processes. Their framework, KYC2, uses Hyperledger Indy to create an identity management ecosystem that verifies clients' identity once and stores the result on their mobile devices for future use. Schlatt et al. [30] built on KYC2 to design a more comprehensive framework that can automate manual processes, standardize the exchange of KYC documents, and prevent central storage of customer data.

Several other studies explored the use of SSI for access control management in end-user-to-enterprise and IoT use cases. For example, the Self-Sovereign Identity Based Access Control (SSIBAC) was proposed by Rafael et al. [6], a security solution that combines VC and OAuth 2.0 by Fotious et al. [13], a proof of concept decentralised OpenID Connect Provider by Lux et al. [22], and a decentralised IAM framework for IoT named DIAM-IoT by Fan et al. [12].

However, little research has focused on the development of decentralised public key infrastructure with SSI for enterprise-to-enterprise use cases. To the best of our knowledge, this paper presents the first open-access system prototype for an organisation's IdM following SSI principles. This gap motivated our study, which demonstrates the validation of an alternate architecture for X-Road, a data exchange system that relies on PKIX, to migrate to a DPKI constructed with DIDs and VCs.

4 RESEARCH METHOD

To address the problem statement of decentralised identity management in X-Road, we follow the design science research methodology (DSRM) [26]. The DSRM includes six steps: (i) identify the problem and motivation; (ii) define the objective of a solution; (iii) design and development of the artefacts; (iv) demonstration of the designed artefacts in a suitable context; (v) evaluation; and (vi) communication of the artefacts. The first three steps of the DSRM process have been reflected in the previous research paper [4]. In this paper, we build upon the current research findings and present the results of the fourth and fifth steps, namely, demonstration and evaluation, which has resulted in the need for reiterating steps 3-5 for redesign and development of the update and new artefacts. In this paper, we present the proof-of-concept implementation of the DPKI-based X-Road, which has aimed to evaluate the initially created artefacts – the proposed approach to analysing and assessing identity management systems in the context of business operations and information systems, and the DPKI-based architecture for the X-Road system.

For the (re)design, development, demonstration and evaluation of the existing artefacts, we carry out the following process. First, having the high-level architecture, the business objectives for the IdM system and credentials, and the identified limitation of the PKIX-based system, we formulate the design goal for the DPKI-based X-Road system. Second, we define the use cases and elicit the corresponding functional requirements that the proof-of-concept

should meet. After that, we define the technological stack, which would allow PoC to satisfy the defined design goals and requirements, and based on the selected stack, we redefine the DPKI-based architecture for the X-Road system. As the next step, we develop the PoC. Finally, we verify that PoC meets the acceptance criteria and assess its trustworthiness using the assessment model from [4].

5 DESIGN AND IMPLEMENTATION

In the previous work [4], the existing in X-Road PKIX-based process of member management and the proposed DPKI-based process have been modelled. In this section, we validate the previously created set of artefacts through the implementation of a proof-of-concept DPKI-based X-Road system.

5.1 Design goals and requirements

While the aim of this study is to validate the technical feasibility of DPKI-based X-Road implementation, the proof-of-concept implementation is limited to the software engineering process and leaves out of scope the establishment of the governance frameworks needed for the PoC. We assume that PoC operates in settings where organisations which use X-Road have established a self-sovereign identity governance model and ecosystem [27]. Thus, a defined governance authority has described the trust framework through policies, procedures and mechanisms for SSI-based credentials and identity management. Additionally, we assume that the VCs are issued following the mentioned governance framework, controlled by the identity itself, and stored in their identity wallet.

Based on the previous X-Road analysis results, we identify the following goals which DPKI-based X-Road should meet:

- **G1: Decentralised:** secure connection creation between organisations using the system without an intermediary organisation;
- **G2: Granular Access Control:** granular attribute-based access control by replacing X.509 certificates with verifiable credentials that support selective disclosure and zero-knowledge proof;
- **G3: Automated Member Onboarding:** to enable automated verification of credential presentations without reliance on any third parties for the member onboarding processes.

To meet the stated design goals, the PoC should enable the following use cases of the X-Road CS and SS. First, the Central Server should enable the **automatic onboarding** of the SS (UC2). To make this possible, the CS Administrator should be able to **Configure and Start the CS** (UC1). In UC1, the CS administrator configures the communication interfaces between the CS and an SSI agent, as well as the verifiable presentation request for onboarding control and the validity time of a verifiable presentation. In UC2, the SS uses the system to automatically onboard members, i.e., to get an endorsement for an organisation's DID registration transaction.

Meanwhile, X-Road SS in PoC should have enabled the four use cases. The SS administrator should be able to **configure and start SS** the communication interfaces between the Security Server and an SSI agent, as well as the verifiable presentation request for access control and the validity time of a verifiable presentation (UC3). In UC4, the SS administrator uses the Security Server user interfaces to **send an onboarding request**. In UC5 and UC6, the service consumer's IS to **consume service** and service provider's IS to

provide service through their own Security Servers, which perform access control, message signing and verification. The detailed description of use cases, their connection to the design goals, and the elicited functional requirement can be found in [21].

5.2 Design Decisions

To integrate a decentralised public key infrastructure into X-Road, the system developer should make the decision about the three key components with respect to the following pre-requisites:

- (i) **DID method** should store the data to produce DID documents on a distributed ledger;
- (ii) **Implementation of verifiable credentials** should support revocation status check using a revocation registry published on a distributed ledger; the same distributed ledger can be used for the DID method and the implementation of verifiable credentials.
- (iii) **Identity wallet** for integration: X-Road Central Server and Security Server should support integration with an SSI identity agent and wallet that supports the selected DID method and verifiable credential implementation (hereinafter, we will refer to the SSI identity agent that manages the identity wallet as "SSI agent").

The integration with the SSI agent can take two forms, depending on the agent's interfaces. If an agent requires its own connection protocol for credential presentation, the agent should be placed between X-Road components and the external network. If an agent does not have its own communication protocol, X-Road components can connect directly to the external network, and the SSI agent becomes an external service used by X-Road components.

5.3 PoC Implementation

In the PoC², we use the Sovrin DID method, while DID data is stored on an instance of Hyperledger Indy, an SSI-specialised distributed ledger. AnonCreds [10] is chosen to be the verifiable credential implementation since it supports revocation status checks using the revocation registry published on Hyperledger Indy. X-Road components are integrated with Aries Cloud Agent Python (ACA-Py)³, an open-source identity wallet supporting the Sovrin DID method and AnonCreds. Figure 2 depicts the PoC security architecture.

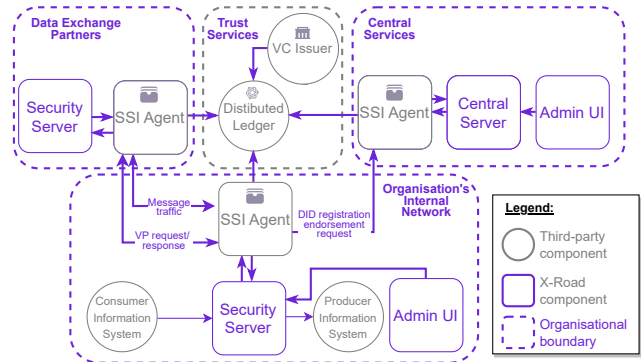


Figure 2: PoC Security Architecture (adapted from [21])

²The source code of the PoC is available at <https://gitlab.cs.ut.ee/ssi-xroad/ssi-xroad>

³The source code of the modified Aries Cloud Agent Python is available at <https://gitlab.cs.ut.ee/ssi-xroad/aries-cloudagent-python>

In the PoC, we assume that the Security Server is managed by the organisation that uses it as a Client, and therefore, we integrate the ACA-Py identity wallet into the Security Server. Thereby, ACA-Py is placed instead of the signer component in the existing X-Road Security Server and is responsible for managing keys and certificates for signing messages. Additionally, ACA-Py establishes a secure channel with other Security Servers with DIDcomm for the message exchange, removing part of the responsibility from the Proxy component in the Security Server. DID communication (DIDComm) is a messaging methodology [11] that provides secure and private communication based on the concept of DIDs.

Hyperledger Indy (Distributed Ledger). Hyperledger Indy is a distributed ledger purpose-built to be a verifiable data registry for storing DIDs and DID documents, credential schema, and revocation status. In the PoC, we use VON Network [14], an open-source project, to set up a Hyperledger Indy Node network for development. VON Network has additional development features that help demonstrate the PoC, including a user interface for browsing ledger transactions, the status of nodes and DID registration. There are four validator nodes running in the VON network. The authorisation rules of the network are kept as default. With the default settings, a user with the role TRUSTEE/STEWARDS/ENDORSER can add a new identity owner (user without a role). This rule affects the onboarding process in PoC, which is to have an endorser able to endorse a DID registration transaction from an organisation. The configuration of the Indy network is out of the scope of the PoC. In a production network like the Sovrin MainNet ⁴, DID registration operation should be permissioned. There should be more validator nodes in the network. The authorisation rules should also be carefully reviewed to meet the organisational and X-Road instance policies since it affects the trust model of the network as well as the network consumers. For example, the rule mentioned above can be set that a trustee or steward can add a new identity owner, but at least three endorers are required to add a new identity owner.

Aries Cloud Agent Python (SSI agent). In the PoC, we assumed that each organisation controls an Aries Cloud Agent Python (ACA-Py) instance as their SSI agent (Aries agent). The PoC uses a number of Aries protocols supported by ACA-Py. DID Exchange Protocol is used for making connections between agents [33]. Issue Credential Protocol 2.0 is used for issuing credentials [19]. Present Proof Protocol 2.0 is used for presenting proofs [18].

As one of the original design goals of X-Road is to have messages usable as digital evidence, creating non-repudiable messages (signed messages) is one of the features of DPKI-based X-Road. The SSI agent that controls the identity verification key should be responsible for creating signatures without sharing the private key with other components. However, ACA-Py does not expose an interface for signing payload. Instead, the signing function is used internally within protocol implementations. At the time of writing, the only protocol that supports non-repudiable message exchange is Non-Repudiable Signature for Cryptographic Envelope. Currently, it is in Proposed state and is not supported by ACA-Py [16]. Thus, the PoC is also extended with the implementation of a non-repudiable message exchange protocol.

⁴<https://sovrin.org/overview/>

In the non-repudiable message exchange protocol, there are two roles, "Requester" and "Responder", and three message types, "Request", "Response", and "Denial". A requester initiates the protocol by making a request to a responder, and the responder can either deny or send a response. The payload within a request or response message is signed by the sender verification key. In the future, this protocol is expected to be replaced by a well-recognized community-accepted protocol.

In the PoC, ACA-Py replaces the signer and proxy components in the existing X-Road SS. Signer used to be responsible for managing keys and certificates used for signing messages. ACA-Py also becomes responsible for transmitting messages in a secure channel (with DIDcomm) which removes the usage of Proxy component of the Security Server for the message exchange.

X-Road Central Server. The Central Server in PoC is a Spring Boot Application developed with Java. It provides automated endorsement service to SSs connected with it after requesting and receiving a verifiable presentation. The proof request CS sends to SS for onboarding is configurable. In the demonstration ⁵, the proof request requests three attributes name, registryCode and established from a credential with schema name Business Registration Certificate. Listing 1 shows the onboarding proof request specified in JSON format.

Listing 1: Onboarding Proof Request

```
{
  "name": "Proof of Business Registration Certificate",
  "version": "1.0",
  "requested_attributes": {
    "0_business_uuid": {
      "names": ["name", "registryCode", "established"],
      "restrictions": [{"schema_name": "Business
        Registration Certificate"}]}},
  "requested_predicates": {}
}
```

X-Road Security Server. As some core functionalities of the SS are delegated to ACA-Py, a lightweight SS is implemented for handling the operational logic of X-Road in the PoC, including member onboarding, message mediation, and access control. While the existing Security Server supports multi-tenancy, the SS in PoC is designed for a single organisation. Multi-tenancy can be achieved by using the multi-tenancy feature of ACA-Py. The SS in PoC is a Spring Boot Application developed with Java.

The SS Management REST API exposes an endpoint for member onboarding. When invoked with an endorser DID, the Security Server instructs ACA-Py to connect with that endorser's Aries agent and presents proof of possession for the required credentials for onboarding. Listing 2 shows an example onboarding request made to the endorser identified with the identifier did: sov:SGrjRL82Y9ZZbzhUDXokvQ.

Listing 2: Onboarding Request

```
POST /management/onboard HTTP/1.1
Host: localhost:8001
Accept: application/json
```

⁵The Git repository with the demonstration steps: <https://gitlab.cs.ut.ee/ssi-xroad/ssi-xroad/-/blob/main/docs/demo.md>

Content-Type: application/json

Content-Length: 43

```
{"endorserDid": "SGrjRL82Y9ZZbzhUDXokvQ"}
```

The SS Proxy API is responsible for mediating HTTP messages between service consumers and providers. It exposes an endpoint (/x-road/information system's DID/path) for forwarding requests to other X-Road members' ISs. The Proxy encodes HTTP requests from service consumers, decodes HTTP responses from service providers, and sends/receives the payload through ACA-Py using the non-repudiable message exchange protocol. Listing 3 shows the HTTP request sent to an information system identified by did: sov: 2wJPYULfLLnYTEFYzByfUR through a Security Server.

Listing 3: HTTP Request through Security Server

```
GET /x-road/2wJPYULfLLnYTEFYzByfUR/books/3 HTTP/1.1
Host: localhost:8001
```

Before forwarding requests (as a SS of the service consumer) and after receiving requests (as a SS of the service provider), the Proxy sends a verifiable presentation proof request to the other party. If any party fails to present the requested proof, the message exchange process aborts and an error message is returned to the requester. The default proof request is the same as the one for onboarding (see Listing 1), but it can be configured to be more fine-grained. For example, the request may require more than one credential and include predicates (see Listing 4). The example shows the request where the data can be provided only to the service consumer that has credentials about business registration and membership in Startup Estonia association which is issued not earlier than 01.01.2020.

Listing 4: Custom Proof Request for Access Control

```
{"name":
  "Proof of Business Registration Certificate And Startup
  Membership",
"version": "1.0",
"requested_attributes": {
  "0_business_uuid": {
    "names": ["name", "registryCode", "established"],
    "restrictions": [{
      "schema_name": "Business Registration
      Certificate"}]},
  "0_startup_uuid": {
    "names": ["name", "membershipCode"],
    "restrictions": [{
      "schema_name": "Startup Estonia Membership"}]}},
"requested_predicates": {
  "0_startDate_GE_uuid": {
    "name": "startDate",
    "p_type": ">=",
    "p_value": 20200101,
    "restrictions": [{"schema_name": "Startup
      Estonia Membership"}]}}
```

A PoC Security Server UI is developed for member onboarding and viewing message exchange records. For demonstration purposes, it also provides UI for viewing connection and credential records in ACA-Py and requesting credentials from Issuer.

5.3.1 Network Activities. Applicants wishing to join the PoC X-Road instance initiates the onboarding flow using the Management REST API with a specific endorser DID. Information about endorser(s) for X-Road onboarding should be made publicly available on the Indy ledger. In the PoC, the endorser's DID can be found using VON network's transaction browser. Upon request, the applicant's Security Server connects with the endorser's Security Server through their own Aries agents using the DID exchange protocol. Once connected, both Security Servers set their roles for the connection. Applicant's Security Server sets its role to be "Transaction Author", whereas endorser's Security Server sets its role to be "Transaction Endorser". Endorser's Security Server then requests proof of possession for the required credentials for onboarding using Aries Present Proof Protocol 2.0. Once the proof presentation is completed, the applicant's Security Server creates a new DID and sends a DID registration transaction to the endorser for endorsement. Endorser's Security Server verifies that it has received the required presentation proof from applicant and endorses the transaction (by adding its signature). Finally, the transaction is sent back to the applicant's Security Server who then requests network nodes to write the transaction to the ledger. The onboarding process completes when the applicant's DID is registered on the ledger so that it can be discovered by other X-Road members.

Message Exchange and Access Control. The service client initiates a message exchange flow by sending a request to the proxying endpoint of its SS. The service client's SS connects with the service provider's SS. Once connected, the service consumer's SS sends a presentation proof request to the service provider's Security Server for authentication and authorisation. After receiving and verifying the proof, the service consumer's SS encodes the HTTP request as a JSON payload and sends it through ACA-Py using the non-repudiable message exchange protocol. Upon request, the service provider's SS sends a presentation proof request to the service consumer's SS for authentication and authorisation. After receiving and verifying the proof, the service provider's SS decodes the message payload and forwards the HTTP request to its information system. The information system returns an HTTP response which is then encoded and sent back to the service consumer through ACA-Py using the non-repudiable message exchange protocol. If any party fails to present the requested proof, the message exchange protocol aborts and an error message is returned to the service consumer.

6 EVALUATION

The proof of concept is evaluated against functional requirements and acceptance criteria. An X-Road network instance with PoC and auxiliary components is set up to test whether the acceptance criteria are met. Simulations of member onboarding and data exchange under different configurations are conducted to study the behaviour of the PoC components. Lastly, a theory-based assessment compares the system quality of the PoC implementation to that of the existing X-Road.

An X-Road network instance has been set up with the PoC implementation for evaluating the functional requirements. To become a member of this instance, organisations must have obtained an X-Road membership contract with the X-Road governing authority as verifiable credential in its SSI agent. In the network there should be a single Central Server and two Security Servers. There should be a separate SSI agent (ACA-Py instance) for every CS and SS.

Two components have been implemented to assist with the evaluation. The first component is a web service as the service provider's information system (has been implemented using Java back-end programming language). It exposes REST APIs for adding and retrieving book records. The second component is a web service that automatically issues credentials on request. It consists of a controller server implemented using Java back-end programming language and an ACA-Py instance. Two types of credentials can be requested. The first one is called "X-Road Membership Contract" and is used for evaluating onboarding-related functional requirements. It contains three attributes, namely "name", "registryCode", and "established". The second credential type is called "Startup Estonia Membership" and is used for evaluating access control-related functional requirements. It contains three attributes, namely "name", "membershipCode", and "startDate". Based on the acceptance criteria of the elicited functional requirements, the PoC implementation meets the design goals and enables decentralised connection (G1), granular access control (G2), and conditionally enables automated member onboarding (G3). Thus, depicted in Fig. 2 architecture confirms the technical feasibility of the DPKI-based X-Road.

Using the assessment model from [4], we evaluate the changes in system quality that define the trustworthiness of the X-Road. Thus, we compare changes in IdM systems (PKIX-based and DPKI-based PoC) in the three dimensions: security, control and reliability. Firstly, security is assessed by considering the system's vulnerability to high-risk threats. The PoC system reduces the risk of denial-of-service attacks by distributing a revocation status list across decentralised ledger nodes, thus reducing the computational demand on any single machine. Moreover, the storage of credentials by the identity holders and the distribution of a revocation status list eliminates the threat of a single point failure to which traditional PKIX systems are prone (CAs are the targeted attack point) [4]. Additionally, the system generates fresh non-revocation proof and uses mechanisms like nonces to prevent replay attacks, increasing its security level compared to the existing X-Road. Secondly, the reliability of the PoC is evaluated based on the dependence on external social actors, systems, and systematic delay. The PoC depends on external credential issuers to issue and update the certificate revocation status. Such change moves the expected delay on the issuance of the credential to a different stage, and that should reduce latency when adding to X-Road if the entity is already added earlier to some SSI system. As the PoC introduces a dependency on SSI agents, the dependence on external systems remains unchanged. Thirdly, control over the credentials is evaluated based on the level of system responsibility and privacy control. The PoC system manages the credentials and key materials through external SSI agents, relieving the direct system's control over credentials. However, the level of privacy control that a member has over their identity increases due to the use of credential implementation that supports selective disclosure and predicates.

7 CONCLUSION

X.509 certificates are widely used for secure communication due to the mature ecosystem of tools, libraries, and protocols. However, PKIX's centralised trust model and scalability issues with its validity checking mechanisms, have led to the emergence of alternative decentralised public key infrastructures and Decentralised Identifiers (DIDs). DIDs allow individuals to create unique identifiers without intermediaries, which can be used for authentication across different systems. Used additionally to DIDs, Verifiable credentials introduce a degree of centralisation through the need for trusted issuers. These issuers are similar to certificate authorities and can cause the same single-point-of-failure issues as traditional PKI. However, there are lessons to be learned from the development of DIDs and verifiable credentials that could improve traditional PKI, such as binding physical identity to a DID instead of a public key and enabling verifiable presentation. Traditional PKI can also learn from DLT-based revocation mechanisms to provide a scalable and privacy-preserving way for certificate validity checks.

This paper demonstrates the use of the design science research approach to the problem of the use of decentralised public key infrastructure (DPKI) with decentralised identifiers (DIDs) and verifiable credentials (VC) to establish trust between information systems in the X-Road system. The potential benefits and limitations of DPKI were examined in the context of the X-Road data exchange system. A proof-of-concept (PoC) was implemented using open-source SSI technologies from the Hyperledger Indy ecosystem. The process of the PoC design, development and selection of the technologies has resulted in the update of the architecture, which we were validating. Thereby, the usage of the design science approach and its validation loop has helped us to tackle the stated problem for the DPKI-based data exchange system development. The PoC demonstrated that DIDs and VCs could replace X.509 certificates in PKIX, and the use of SSI technologies can improve the subject's control over their credentials. The scalability issues for credential revocation status checks still exist, but using distributed ledger technology-based VCs can alleviate those problems.

The presented study has limitations in that the design may be biased towards the Hyperledger Indy ecosystem and the assumption that all X-Road members have their own SSI agent. In future work, we will explore the selection of other distributed ledger-based SSI ecosystems. Also, we will explore the integration of DIDs and other metadata into X.509 certificates and the extension of X.509 certificates [9] to enable verifiable presentation without the original certificate following the idea briefly described in [5].

ACKNOWLEDGMENTS

This paper is supported by the European Union under Grant Agreement No. 101087529. Views and opinions expressed are however those of the author(s) only and do not necessarily reflect those of the European Union or European Research Executive Agency. Neither the European Union nor the granting authority can be held responsible for them.

REFERENCES

- [1] Christopher Allen, Arthur Brock, Vitalik Buterin, Jon Callas, Duke Dorje, et al. 2015. *Decentralized public key infrastructure. A White Paper from Rebooting the Web of Trust*. Technical Report.
- [2] Christopher Allen, Arthur Brock, Vitalik Buterin, Jon Callas, Duke Dorje, Christian Lundkvist, Pavel Kravchenko, Jude Nelson, Drummond Reed, Markus Sabadello, Greg Slepak, Noah Thorp, and Harlan T Wood. [n.d.]. *Decentralized Public Key Infrastructure A White Paper from Rebooting the Web of Trust*.
- [3] Mariia Bakhtina, Raimundas Matulevičius, Ahmed Awad, and Petteri Kivimäki. 2022. *Rebooting Trust Management in X-Road*. Technical Report. Nordic Institute for Interoperability Solutions (NIIS).
- [4] Mariia Bakhtina, Raimundas Matulevičius, Ahmed Awad, and Petteri Kivimäki. 2023. On The Shift to Decentralised Identity Management in Distributed Data Exchange Systems. In *The 38th ACM/SIGAPP Symposium on Applied Computing (SAC '23), March 27-March 31, 2023, Tallinn, Estonia*. Association for Computing Machinery, New York, NY, USA. <https://doi.org/10.1145/3555776.3577678>
- [5] Paul Bastian, Carsten Stöcker, and Steffen Schwalm. 2022. Combination of x509 and DID/VC for inheritance properties of trust in digital identities. In *Open Identity Summit 2022*. Gesellschaft für Informatik e.V., Bonn, 137–142. https://doi.org/10.18420/OID2022_13
- [6] Rafael Belchior, Benedikt Putz, Guenther Pernul, Miguel Correia, André Vasconcelos, and Sérgio Guerreiro. 2020. SSIBAC: self-sovereign identity based access control. In *2020 IEEE 19th International Conference on Trust, Security and Privacy in Computing and Communications (TrustCom)*. IEEE, 1935–1943.
- [7] Kim Cameron. 2005. The laws of identity. *Microsoft Corp* 12 (2005), 8–11.
- [8] David Cooper, Stefan Santesson, Stephen Farrell, Sharon Boeyen, Russell Housley, and William Polk. 2008. *Internet X. 509 public key infrastructure certificate and certificate revocation list (CRL) profile*. Technical Report. Internet Engineering Task Force.
- [9] David Cooper, Stefan Santesson, Stephen Farrell, Sharon Boeyen, Russell Housley, and William Polk. 2008. *Internet X. 509 public key infrastructure certificate and certificate revocation list (CRL) profile*. Technical Report RFC 5280.
- [10] Stephen Curran, Artur Philipp, Hakan Yildiz, Sam Curren, and Victor Martinez Jurado. [n.d.]. AnonCreds Specification. <https://hyperledger.github.io/anoncreds-spec/>. Last accessed 10-Apr-2023.
- [11] Decentralized Identity Foundation. [n.d.]. DIDComm Messaging v2.1 Editor's Draft. <https://identity.foundation/didcomm-messaging/spec/v2.1/>.
- [12] Xinxi Fan, Qi Chai, Lei Xu, and Dong Guo. 2020. DIAM-IOT: A Decentralized Identity and Access Management Framework for Internet of Things. In *Proceedings of the 2nd ACM International Symposium on Blockchain and Secure Critical Infrastructure*. ACM, 186–191.
- [13] Nikos Fotiou, Evgenia Faltaka, Vasilis Kalos, Anna S. Kefala, Iakovos Pittaras, Vasilios A. Siris, and George C. Polyzos. 2022. Continuous authorization over HTTP using Verifiable Credentials and OAuth 2.0. In *Open Identity Summit 2022, Copenhagen, Denmark, July 7-8, 2022 (LNI, Vol. P-325)*. Gesellschaft für Informatik e.V., 39–50. https://doi.org/10.18420/OID2022_03
- [14] Government of British Columbia Canada. [n.d.]. VON Network. <https://github.com/bcgov/von-network>. Last accessed 10-Apr-2023.
- [15] The Sovrin Governance Framework Working Group. 2023. Sovrin Glossary V3. <https://sovrin.org/wp-content/uploads/Sovrin-Glossary-V3.pdf>. Last accessed 10-Apr-2023.
- [16] Kyle Den Hartog. 2023. Aries RFC 0066: Non-Repudiable Signature for Cryptographic Envelope. <https://github.com/hyperledger/aries-rfcs/blob/070b325ef4a55005d79d03eb629f0399f3a0dfc4/features/0066-non-repudiable-cryptographic-envelope/README.md>. Last accessed 10-Apr-2023.
- [17] Carly Huitema, Daniel Bacheneimer, Darrell O'Donnell, Drummond Reed, Jacques Bikoundou, Judith Fleener, Karen Young, Kaliya Hand, John Kneiss, Karl Jordan, Lynn Bendixsen, PA Subrahmanyam, Sankarshan Mukhopadhyay, Scott Perry, Victor Syntez, Vikas Malhotra, and Wenjing Chu. 2023. Introduction to Trust Over IP. Version 2.0. <https://trustoverip.org/wp-content/uploads/Introduction-to-ToIP-V2.0-2021-11-17.pdf>. Last accessed 10-Apr-2023.
- [18] Nikita Khateev and Stephen Curran. 2023. Aries RFC 0454: Present Proof Protocol 2.0. <https://github.com/hyperledger/aries-rfcs/blob/070b325ef4a55005d79d03eb629f0399f3a0dfc4/features/0454-present-proof-v2/README.md>. Last accessed 10-Apr-2023.
- [19] Nikita Khateev, Stephen Klump, and Stephen Curran. 2023. Aries RFC 0453: Issue Credential Protocol 2.0. <https://github.com/hyperledger/aries-rfcs/blob/070b325ef4a55005d79d03eb629f0399f3a0dfc4/features/0453-issue-credential-v2/README.md>. Last accessed 10-Apr-2023.
- [20] Petteri Kivimäki. 2020. Resisting Failure. <https://www.niis.org/blog/2020/11/20/resisting-failure>.
- [21] Kin Long Leung. 2023. *Decentralized Public Key Infrastructure for X-Road*. Master's thesis. University of Tartu, Institute of Computer Science, Tartu.
- [22] Zoltán András Lux, Dirk Thatmann, Sebastian Zickau, and Felix Beierle. 2020. Distributed-Ledger-based Authentication with Decentralized Identifiers and Verifiable Credentials. In *2020 2nd Conference on Blockchain Research & Applications for Innovative Networks and Services (BRAINS)*. 71–78. <https://doi.org/10.1109/BRAINS49436.2020.9223292>
- [23] Alexander Mühle, Andreas Grüner, Tatiana Gayvoronskaya, and Christoph Meinel. 2018. A survey on essential components of a self-sovereign identity. *Computer Science Review* 30 (2018), 80–86. <https://doi.org/10.1016/j.cosrev.2018.10.002>
- [24] Nordic Institute for Interoperability Solutions (NIIS). [n.d.]. X-Road Architecture. https://docs.x-road.global/Architecture/arc-g_x-road_arhitecture.html. Last accessed 10-Apr-2023.
- [25] Nordic Institute for Interoperability Solutions (NIIS). 2020. X-Road Academy. <https://x-road.thinkific.com/>.
- [26] Ken Peffers, Tuure Tuunanen, Marcus A. Rothenberger, and Samir Chatterjee. 2008. A Design Science Research Methodology for Information Systems Research. *J. Manag. Inf. Syst.* 24, 3 (2008), 45–77.
- [27] Alex Preukschat and Drummond Reed. 2021. *Self-sovereign identity*. Manning Publications, Shelter Island, NY.
- [28] Drummond Reed, Manu Sporny, Dave Longley, Christopher Allen, Ryan Grant, Markus Sabadello, and Jonathan Holt. 2020. Decentralized Identifiers (DIDs) v1.0.
- [29] Stefan Santesson, Michael Myers, Rich Ankney, Ambarish Malpani, Slava Galperin, and Carlisle Adams. 2013. *X.509 Internet Public Key Infrastructure Online Certificate Status Protocol - OCSP*. Request for Comments RFC 6960. Internet Engineering Task Force. <https://doi.org/10.17487/RFC6960> Num Pages: 41.
- [30] Vincent Schlatt, Johannes Sedlmeier, Simon Feulner, and Nils Urbach. 2022. Designing a framework for digital KYC processes built on blockchain-based self-sovereign identity. *Information & Management* 59, 7 (2022), 103553.
- [31] Reza Soltani, Uyen Trang Nguyen, and Aijun An. 2020. Decentralized and Privacy-Preserving Key Management Model. In *2020 International Symposium on Networks, Computers and Communications (ISNCC)*. IEEE, 1–7.
- [32] The Hyperledger Foundation. [n.d.]. Hyperledger Indy SDK. <https://github.com/hyperledger/indy-sdk>. Last accessed 10-Apr-2023.
- [33] Ryan West, Daniel Bluhm, Matthew Hailstone, Stephen Curran, Sam Curren, and George Aris. 2023. Aries RFC 0023: DID Exchange Protocol 1.0. <https://github.com/hyperledger/aries-rfcs/blob/070b325ef4a55005d79d03eb629f0399f3a0dfc4/features/0023-did-exchange/README.md>. Last accessed 10-Apr-2023.
- [34] World Wide Web Consortium (W3C). 2022. Verifiable Credentials Data Model v1.1. <https://www.w3.org/TR/vc-data-model>.